Exam: Secure Computer Systems 1
1DT072
2024–08–21

Teacher: Paul Fiterau-Brostean (tel. 0040720114646)
Time: 14.00–19.00

Instructions: The exam has 11 sections. To pass the exam you need to get approximately 2/3 of the possible total score.

Hand in **only the answer sheet**, with your answers clearly marked. If you make mistakes, ask for another answer sheet. If you mark more than one answer to a question, you will get no score. **Please also read** the instructions on the answer sheet!

Good luck!!

---

1 Foundations

Question 1 Unauthorized modification of information is a direct breach of which security property:

A. confidentiality

B. privacy

C. integrity

D. availability

E. authenticity

Question 2 Consider a spoofing attack – which of the basic security properties is most affected?

A. authenticity

B. confidentiality

C. integrity

D. accountability

E. availability

Question 3 Which of the following is **TRUE** about the classic design principles of Saltzer and Schroeder?

A. *Complete mediation* says every possible situation should be considered (mediated) when implementing the secure kernel

B. *Open design* says security should not be ensured through secrecy

C. *Economy of mechanism* means to use security mechanisms economically, to minimize overhead

D. *Separation of privilege* says protection mechanisms should be separated from each other, to avoid unintended overlap

E. *Least common mechanism* means you should use the least common, i.e. most unusual, security mechanism

---

2 Web and data security

Question 4 Forbidding the use of special characters does not help at all against which attack?

A. command injection

B. path traversal

C. SQL injection

D. SYN flood attack

E. XSS

Question 5 In an SQL injection attack, which is **TRUE**?

A. The attack can be best prevented by the use of *parameterized queries*

B. Race conditions are fundamentally important to protect against SQL injections

C. Filtering SQL comment characters makes the attack impossible

D. Client-side protections are sufficient to defend against the attack

E. The attacker can inject machine code in the SQL query through a stack overflow

---

Question 6 To protect against a XSS (cross-site scripting) attack, which method is **most** effective?

A. That the web server runs in an isolated environment

B. Treating user input as data

C. Disabling cookies in your web browser

D. To trust only web servers that use HTTPS

E. That the web server follows the HTML5 standard

Question 7 *Homographic encodings* are used in phishing attacks to:

A. bypass web filters

B. mimic valid addresses

C. attack browser display engines

D. crash mail clients

E. limit access DNS service providers

---

3 Asymmetric Cryptography and Signatures

Question 8 A group of 10 users want to establish secure channels among themselves. This means, every two users should be able to communicate in a way that is indecipherable by the other users. For this purpose, they are deciding between using either symmetric or asymmetric cryptography. Which of the following statements is **TRUE**?

A. Adding a new user to the group is easier for symmetric cryptography (i.e., it entails generating fewer keys)

B. Asymmetric encryption algorithms are generally faster

C. A user would have to know more secret keys if symmetric cryptography was used

D. Symmetric cryptography requires fewer keys in total

E. Leakage of a secret key would compromise more secure channels if symmetric cryptography is used

---

Question 9 You are given the certificate hierarchy in Figure 1.

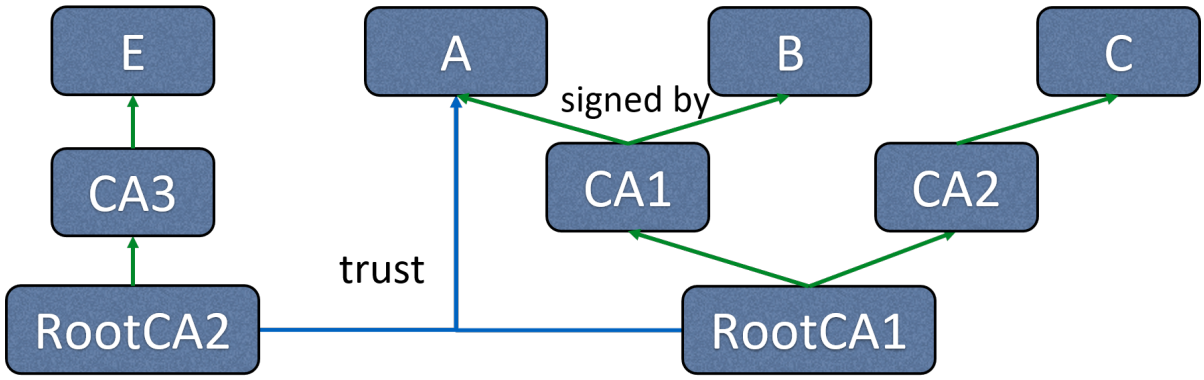

Figure 1 Certificate Hierarchy

Entity A's trust store contains only RootCA1's and RootCA2's self-signed certificates ($Cert_{RootCA1(RootCA1)}$ and $Cert_{RootCA2(RootCA2)}$). Select the certificate chain that A will be able to successfully validate. Note that $Cert_{X(Y)}$ can be interpreted as a certificate containing Y's public key that has been signed by X.

A. $Cert_{CA1(B)}$, $Cert_{RootCA1(CA2)}$

B. $Cert_{CA1(B)}$

C. $Cert_{CA3(E)}$, $Cert_{RootCA2(CA3)}$

D. $Cert_{CA2(C)}$

E. $Cert_{CA2(C)}$, $Cert_{RootCA2(CA3)}$

Question 10 In the first lab, you used S/MIME certificates for secure email. Which of the following is **TRUE**?

A. Encrypting a digitally signed email requires the certificate of the receiver

B. Decrypting a digitally encrypted email requires the certificate of the sender

C. Sending a digitally signed email requires the certificate of the receiver

D. Sending a digitally encrypted email requires the certificate of the sender

E. Verifying a digitally signed email requires the certificate of the receiver

---

4 Sandboxing and Virtualization

Question 11 AppArmor is used to restrict the capabilities of a program, and in doing so protect the operating system. Which of the following is the design principle (by Saltzer et al) does AppArmor **most specifically** address?

A. *Least common mechanism*

B. *Complete mediation*

C. *Least escalation*

D. *Psychological acceptability*

E. *Open design*

Question 12 The terms sandboxing and virtualization can be easy to confuse. What is **TRUE** of the following?

A. Virtualization is mainly a software feature, and not helped much by hardware support

B. Sandboxing abstracts underlying components

C. Sandboxing protects 'sandboxed' applications from viruses affecting the system

D. Virtualization can protect the system against viruses

E. Sandboxing may limit an application's access to system resources

---

5 Identification and authentication

Question 13 A brute-force attack uses randomly generated passwords and **does not** re-use passwords that proved invalid. Assuming the number of possible passwords is n, give the probability of cracking a password in at most k attempts, where $0 < k < n$.

A. 0

B. $1/n$

C. $2/n$

D. k/n

E. $1/n^k$

Question 14 You should of course *never* store passwords in plain text, at any time. Instead, always use *salted hashing*. How does this work – what of the following is **TRUE**?

A. The salt is used to make the password longer, but is not stored

B. It is a bad idea to save the salt you used for hashing the password

C. It is efficient and secure to use the same salt for all your passwords as long the salt is kept secret

D. The salt is hashed together with the password and the result is stored together with the salt

E. When checking an input password, you compare its hash value with the stored salt value

---

6 Information flow

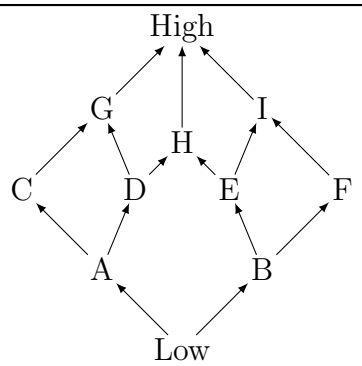

Figure 2 BLP lattice. Arrows indicate the ordering in the lattice.

Question 15 The Bell-LaPadula model (BLP) deals with security levels and categories, typically ordered as a lattice. What is **TRUE** for subjects and objects in the lattice in Figure 2, using the rules of the Bell-LaPadula model?

A. A subject with level B can read an object with level I

B. A subject with level H can read an object with level B

C. A subject with level H can write an object with level B

D. A subject with level A can read an object with level B

E. A subject with level G can write an object with level D

Question 16 y and z are variables, such that $y, z \in \{0, ..., 15\}$ with equal probabilities. The variables are secret, and used in programs whose execution produces the non-secret output x. Select the program whose execution leaks the most information regarding y.

A. $\boxed{x := (y + z) \bmod 4}$

B. $\boxed{x := y^z}$

C. $\boxed{x := y \text{ xor } z}$

D. $\boxed{x := y * z}$

E. $\boxed{x := (y + z) \bmod 2}$

---

7 Access control

Question 17 The access control matrix can be implemented using Capability Lists (CL) or Access Control Lists (ACL). Which is better, when?

A. ACLs often allow delegation of rights between subjects

B. ACLs are better when subjects often need to have all their rights revoked

C. ACLs are better for settings where objects have owners, who can quickly see who has access to their objects

D. CLs are better when the owner of an object often needs to revoke access rights to it

E. CLs give a better overview of which subjects have access to a particular object

---

Question 18 Mandatory Access Control (MAC) differs from Discretionary Access Control (DAC). What of the following is **FALSE**?

A. "Classic" Linux file protection supports MAC

B. On a standard Linux system, the root user can read and write any file

C. Role-Based Access Control is typically MAC

D. In a MAC system, central policies define the access rights

E. When using DAC, all objects typically have an owner

---

8 Software security

Question 19 In Lab 3, you used Metasploit to attack the different systems. For a successful attack, you needed a *vulnerability*, an *exploit* and a *payload*. What is the relationship between an exploit and a vulnerability?

A. An exploit is used to expose a vulnerability

B. A vulnerability is a type of exploit

C. Exploits and vulnerabilities are unrelated

D. A vulnerability is the result of an exploit

E. An exploit is a type of vulnerability

Question 20 The C program (below) executes a `sensitive` function only if the user provides a correct 3-digit number. The constant `PIN` stores the correct PIN, but its contents are unknown, other than the fact that it is a 4-byte string in which a 3-digit number is stored. The binary is compiled for a 32-bit architecture.

```
#define PIN "..." // 4-byte string storing 3-digit number
void sensitive () {
  // . . .
}
int main() {
  char secret[] = PIN;
  char input[4]; // make room for end of string char '\0'
  printf("Input 3-digit PIN: \n");
  gets(input);
  if (strncmp(input, secret, 3) == 0) {
    printf("Authenticated successfully\n");
    sensitive();
    return 1;
  } else {
    printf("PIN is incorrect\n");
    return 0;
  }
}
```

Execution of the the program uses a stack. Assuming the input is '123', just before executing the `strncmp` statement, the stack is like below ('*' stands for unspecified):

`input`	1	2	3	\0
`secret`	*	*	*	\0
`saved frame pointer`	*	*	*	*
`saved return address`	*	*	*	*
	...			

Select the input which would give you the best chance at passing the PIN check, running the `sensitive` function, *and* terminating gracefully.

A. `1234`

B. `12345678`

C. `1111`

D. `11111111`

E. `111111111111111111111111`

---

9 Privacy and Tracking

Question 21 A web server can find out a lot of information about the clients visiting its web pages, e.g. by sending Javascript code which gets executed in the web browser. (Note that this is not an XSS attack, since the information is sent back to the same web server that sent the Javascript code.)

Suppose you run a web server and want to keep track of your clients. Which of the following would be the *most* useful information that an HTTP request could contain?

A. the size of the browser window

B. the language preferences in the browser

C. the universal time (UTC) when doing the request

D. a session cookie

E. user agent string (which describes the web browser to the server)

Question 22 Tor browser protects you from being tracked when surfing the web primarily by:

A. launching threads for separate websites in separate containers

B. disabling script execution

C. using highly customized parameters in HTTP requests

D. making your browser appear indistinguishable from many others

E. sending a Do-not-track header to tell web services not to track

---

10 Network security

Question 23 A security mechanism provides different forms of protection. What is **FALSE** of the following?

A. IPsec in tunnel model provides confidentiality of IP addresses

B. TLS provides confidentiality of data exchanged between applications

C. Using IMAP over TLS ensures confidentiality between mail server and the connecting mail client.

D. SYN Cookies protect confidentiality in the transport layer

E. S/MIME protects authenticity and confidentiality of email.

Question 24 Having security mechanisms in more than one layer is a good choice. What is **TRUE** of the following?

A. Protecting both the network layer and the transport layer (e.g. using both IPsec and TLS) gives satisfactory protection

B. If S/MIME is used to encrypt all email, everything about your email is hidden from an eavesdropper

C. When WiFi is protected by WPA2 and the network cables are physically protected, no additional encryption is necessary

D. When TLS is used to encrypt data below the application layer, you must still consider confidentiality attacks on that data from the layers below

E. When using HTTPS, one must still consider confidentiality attacks from the layers above

---

11 Ethics in Security

Question 25 (2 points)

An article in The Guardian (*Are you being scanned? How facial recognition technology follows you, even as you shop*) discusses the use of facial recognition in advertisement billboard screens. Cameras capture pictures of shoppers near the billboard, and software analyses e.g. audience demographics/age (in five-year brackets), gender (with 90% precision), and mood (five categories, 80% precision). The resulting data is collected and used to evaluate the advertisement. The company behind the system say that all data collected is anonymous, and emphasize the difference to systems that recognize individuals. (That type of systems is used e.g. in China, tracking people on a large scale.) The issues of data theft are also mentioned in the article.

Analyse the setting by applying **more than one** of the ethical aspects from the Ethics part of the course (e.g. consequences, duties, virtues, freedom, fairness, or relations). How can the companies behind the systems reason from their side, and how can the users reason from theirs?

Answer in the box at the bottom of the answer sheet. (You may want to think and formulate an answer before you write it there.)

Note: For 1 point, you need to show reflection and use basic ethical argumentation. For 2 points, you need to argue showing (relevant) understanding of ethical principles. Just stating "this is what I would do" is not enough for any score at all.

Good luck!

Score	**Exam: Secure Computer Systems 1 (1DT072)** **Date: 2024–08–21**
	Exam code:

Instructions: Mark clearly in the table below ***no more than one*** answer per question, by checking or covering the letter for your choice. ***Hand in only this page.*** If you find one of the questions strange or want to clarify your answer, mark ***the question box*** with a $\star$ and explain ***on the back of this sheet***, e.g, what you think is the problem and what assumptions you had to make to answer the question.

Question	Answer				
1	A	B	C	D	E
2	A	B	C	D	E
3	A	B	C	D	E
4	A	B	C	D	E
5	A	B	C	D	E
6	A	B	C	D	E
7	A	B	C	D	E
8	A	B	C	D	E
9	A	B	C	D	E
10	A	B	C	D	E
11	A	B	C	D	E
12	A	B	C	D	E

Question	Answer				
13	A	B	C	D	E
14	A	B	C	D	E
15	A	B	C	D	E
16	A	B	C	D	E
17	A	B	C	D	E
18	A	B	C	D	E
19	A	B	C	D	E
20	A	B	C	D	E
21	A	B	C	D	E
22	A	B	C	D	E
23	A	B	C	D	E
24	A	B	C	D	E

Answer to question 25 (please write LEGIBLY and only write inside the box):